CNOVI PROGRAMACIÓN WAP

Reporte laboratorio #11: File path traversal Validation of start of path



Lizeth Infante Martínez

Reporte de Laboratorio: File path traversal Validation of start of path

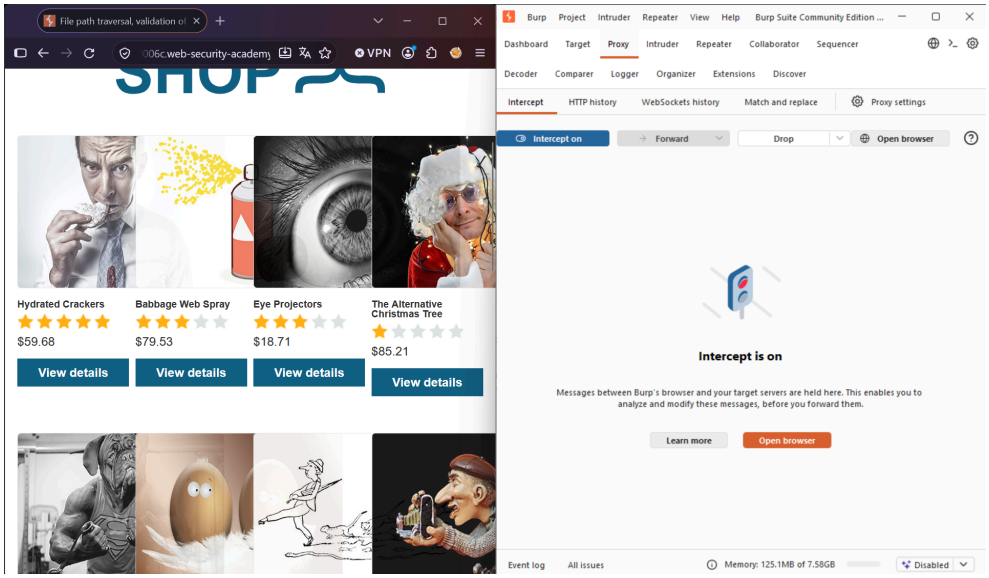
1. Objetivo

Demostrar la vulnerabilidad de salto de directorio cuando la aplicación valida que la ruta suministrada comience con una carpeta esperada (validación de inicio de ruta). Se utiliza Burp Suite para interceptar, modificar el parámetro filename anteponiendo la ruta base requerida (/var/www/images/) seguida de secuencias de salto (../../../) para acceder al archivo restringido del servidor (/etc/passwd).

2. Metodología y Pasos de Resolución

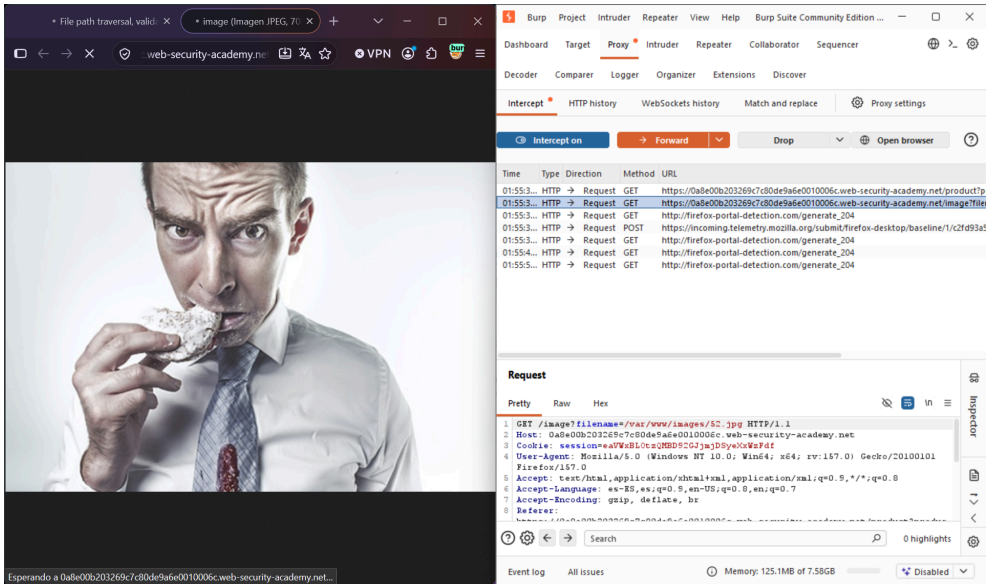
Paso 1: Configurar la intercepción en Burp Suite

- Ve a la pestaña Proxy en Burp Suite y asegúrate de que el botón indique Intercept on (Interceptación activada).



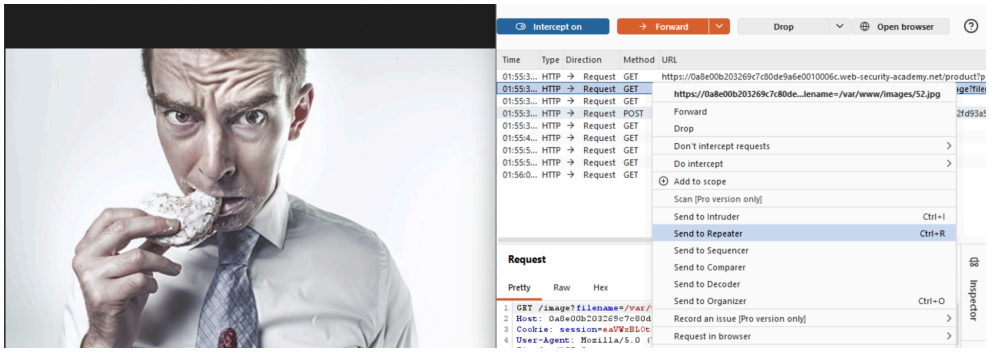
Paso 2: Generar la petición de una imagen de producto

- Dirígete a la ventana del navegador integrada en Burp o a tu navegador configurado con el proxy.
- Haz clic en cualquiera de los productos de la tienda para ver los detalles o cargar una imagen y generar la solicitud HTTP correspondiente.



Paso 3: Interceptar, modificar la solicitud y usar el Repeater

- La petición se pausará en Burp Suite en la pestaña Proxy > Intercept.
- En la lista de HTTP history, localiza la petición correspondiente para cargar la imagen y haz clic derecho para seleccionar Send to Repeater.



- Abre la pestaña Repeater en el menú superior de Burp Suite.
- En el panel de la petición HTTP, ubica la primera línea y modifica el parámetro filename combinando la ruta inicial requerida con las secuencias de salto de directorio para satisfacer la validación y recuperar el archivo objetivo:

  GET /image?filename=/var/www/images/../../../etc/passwd HTTP/1.1

- Haz clic en el botón Send en la esquina superior izquierda de la pestaña Repeater para emitir la solicitud.



3. Verificación y Resultados

- **Panel de Respuesta (Repeater):** Al enviar la petición modificada, revisa el panel de respuesta (Response). Se observa el código de estado 200 OK y el contenido completo del archivo /etc/passwd (líneas de texto que comienzan con usuarios como root:x:0:0..., daemon:x:1:1..., etc.), lo que confirma que la validación de inicio de ruta fue superada y la explotación fue exitosa.
- **Navegador**: Al comprobar el estado en el navegador del laboratorio, se visualiza la notificación de que el reto ha sido completado satisfactoriamente (Congratulations, you solved the lab!).

